OneDrive DLP — Microsoft Purview

Implementation Solution Guide

Version 1.0.0 · 2026-07-07

Contents

Executive Summary — OneDrive for Business DLP (Microsoft Purview) 4

The problem . . . 4

The solution . . . 4

What it delivers . . . 4

Business outcomes . . . 4

Boundaries (so scope is clear) . . . 5

1. Solution Overview — OneDrive for Business DLP (Microsoft Purview) 5

What this solution is . . . 5

Why this matters . . . 6

How it works . . . 6

The two things a OneDrive policy controls . . . 7

The simulate→enforce journey (the core discipline) . . . 7

What you can control . . . 7

Limitations (be honest with buyers) . . . 7

Naming convention (used in every doc and script) . . . 8

The standard deployment model . . . 8

2. Requirements — OneDrive for Business DLP (Microsoft Purview) 8

2.1 Licensing sufficient for the DLP features you will use . . . 8

2.2 DLP-specific least-privilege roles . . . 9

2.3 OneDrive provisioned and the sharing posture understood . . . 9

2.4 A classification intent and a sensitive-information-type inventory . . . 10

2.5 Source data for Exact Data Match (only if EDM is used) . . . 10

2.6 A pilot ring, simulation dwell time, and change control (DLP-specific) . . . 10

2.7 An incident/alert triage owner and destination . . . 11

Global Requirements — Microsoft Purview Solutions 12

1. Microsoft 365 tenant with the required Purview/compliance licensing . . . 12

2. Purview roles (least-privilege) and portal access . . . 12

3. Security & Compliance PowerShell + Graph toolchain . . . 13

4. Data sources & scope in scope . . . 13

5. Compliance, records, privacy & legal stakeholders . . . 13

6. A pilot scope and change control . . . 13

3. Implementation Guide — OneDrive for Business DLP (Microsoft Purview) 14

Phase 0 — Connect and baseline (Assess) . . . 14

Phase 1 — Design the classification layer (SITs & classifiers) . . . 15

Phase 2 — Build the OneDrive DLP policy in SIMULATION (Configure — no user impact) . . . 15

Phase 3 — Measure and tune (drive false positives down) . . . 16
Phase 4 — Enforce in a pilot ring (Pilot) . . . 17
Phase 5 — Expand and harden (Enforce → Operate) . . . 17
Order-of-operations summary . . . 18
5. Testing & Validation — OneDrive for Business DLP (Microsoft Purview) 18
Test A — Detection & enforcement (sensitive content and risky shares are caught) . . . 19
Test B — False-positive rate (adoption gate) . . . 20
Test C — Incident / alert handling (the control is operable) . . . 20
Simulation-first & rollback validation . . . 21
Evidence to capture (for the deliverable record) . . . 21
6. Troubleshooting — OneDrive for Business DLP (Microsoft Purview) 22
Policy / detection . . . 22
External-share condition . . . 23
False positives (the adoption killer) . . . 23
Alerts / incident handling . . . 24
Connectivity / tooling . . . 24
7. Best Practices — OneDrive for Business DLP (Microsoft Purview) 25
Simulate before you enforce — always . . . 25
Separate "at rest" from "shared" — act proportionally . . . 25
Tune for a low false-positive rate (adoption depends on it) . . . 26
Right-size the user experience . . . 26
Coordinate with tenant sharing settings . . . 26
Classification hygiene . . . 26
Operations & governance . . . 27
Stay inside the boundary . . . 27
8. Deliverables Summary — OneDrive for Business DLP (Microsoft Purview) 27
Documentation . . . 27
PowerShell tools (5) — Security & Compliance PowerShell / Graph . . . 28
Definition of done . . . 29
Appendix A — PowerShell Scripts 31

Executive Summary — OneDrive for Business DLP (Microsoft Purview)

The problem

OneDrive for Business is personal cloud storage that fills up with corporate data — customer spreadsheets, contracts, and exports individuals save to work on. Two risks follow: **sensitive content sitting in personal storage**, and **that content being over-shared**, most often as an "anyone with the link" or a direct external share. Left unaddressed, this is a compliance gap and a data-risk exposure that stays invisible until it becomes an incident. The common failed attempt — switching data-loss controls straight to "block" — strips sharing on legitimate collaboration, floods the help desk, and gets turned off within a week.

The solution

Implement **Microsoft Purview Data Loss Prevention (DLP)** for the **OneDrive for Business** location using only the Microsoft Purview portal, Security & Compliance PowerShell, and Microsoft Graph — no third-party tooling. Detection is driven by **sensitive information types** (built-in, custom, **Exact Data Match**, and **trainable classifiers**), and the policy acts on both **sensitive content at rest** and the higher-severity case of **sensitive content shared externally**. The defining discipline is that **every policy is built and proven in SIMULATION first** — Microsoft's built-in test mode that shows what *would* be restricted, with zero user impact — then tuned for a **low false-positive rate**, then enforced to a **pilot ring**, then expanded. The result: risky exposure is controlled without blocking legitimate collaboration.

What it delivers

- A mapped **classification layer** — the right detector for each in-scope data category, reusing built-in types and adding custom/EDM/trainable only for real gaps.
- **OneDrive DLP policies** — an *at-rest* policy for sensitive content stored in OneDrive and an *external-share* policy that targets the over-share specifically, each proven in simulation, tuned, and enforced through policy tips, user justification/override, or restricting external access.
- A **measured false-positive rate** kept at/under an agreed threshold — the difference between a control people trust and one they ignore.
- An **incident/alert triage workflow** so every match is actually acted on, with an evidence trail in Activity Explorer and optional SIEM forwarding.
- **Five PowerShell tools** (posture assessment, policy config/remediation helper, validation reporter, match/false-positive report, scope/health helper) — read-only or `-WhatIf` by default, no credentials in code.

Business outcomes

• **Over-shares controlled** — sensitive files shared "anyone with the link" or externally are

restricted, while internal collaboration is left untouched.

• **Minimal disruption** — simulation-first plus tuning means the control catches exposure without a wave

of false positives, and any policy reverts to simulation instantly if needed.

• **Operable and auditable** — matches raise alerts that are triaged to disposition, with evidence

retained.

• **Self-guided at a fraction of consulting cost** — the same method a specialist would use, documented

and tooled to run in-house.

Boundaries (so scope is clear)

DLP is licensing-/plan-dependent — **custom/advanced classifiers require E5 / E5 Compliance** (verify your tenant); DLP for OneDrive and built-in SITs are broadly available. This solution provides the **technical configuration and the evidence**; *which* data categories are in scope, *which* classifiers legally apply, the **enforced action per category** (e.g. block external sharing vs. warn-and-override), and the **acceptable false-positive threshold** are **compliance, privacy, and legal determinations**, captured alongside the delivered evidence.

1. Solution Overview — OneDrive for Business DLP (Microsoft Purview)

What this solution is

OneDrive for Business is personal cloud storage that fills up with corporate data — customer spreadsheets, contracts, exports, and screenshots that individuals save "just to work on." Two risks follow: **sensitive content sitting in personal storage**, and **that content being over-shared** — most often a document handed out as "anyone with the link" or shared directly to an external address. **Microsoft Purview Data Loss Prevention (DLP)** addresses both by matching the *content* in OneDrive against **sensitive information types** and **classifiers**, and by evaluating **how a file is shared**, then applying a policy action — audit only, warn the user with a **policy tip**, allow with a business **justification/override**, or **block/restrict** access — scoped to the **OneDrive for Business** location.

This solution is a repeatable, evidence-driven way to implement OneDrive DLP using only the **Microsoft Purview portal**, **Security & Compliance PowerShell** (`Connect-IPPSSession`), and **Microsoft Graph** — no third-party tooling. Its defining discipline is that **every policy is built and proven in SIMULATION mode first** (Microsoft's built-in test mode that evaluates policy against real OneDrive content and sharing activity and shows what *would* have matched, without affecting a single user), tuned for a low false-positive rate, and only then moved to enforcement.

> ***Scope boundary.*** *This solution delivers the **technical method and evidence** for OneDrive DLP configuration. *Which* data is regulated, *which* classifiers legally apply, and *what* the enforced action must be for a given data category (e.g. block external sharing outright vs. warn-and-override)*

*are **business, compliance, privacy, and legal determinations** — deferred to those functions. The solution helps you configure and prove the control; it does not make the policy decision.*

Why this matters

• OneDrive is where corporate data quietly becomes **personal-cloud data**. A file shared "anyone with the link" is reachable by anyone that link reaches — inside or outside the company — with no further gate. DLP is the control that detects the sensitive content and clamps the risky share.

• DLP that is switched straight to **enforce** without simulation is the classic failure: it strips sharing on legitimate collaboration, floods the help desk, and gets disabled within a week. Simulation-first is the difference between a control that survives and one that is turned off.

• False positives are the enemy of adoption. A built-in credit-card detector that fires on internal reference numbers trains users to ignore every policy tip. Tuning — confidence levels, instance counts, supporting keywords, and Exact Data Match — is what makes the control trusted.

• The same sensitive-information-type library drives DLP, auto-labeling, and insider risk. Getting the classification layer right for OneDrive pays off across the whole Purview estate.

How it works

1. **Sensitive information types (SITs) and classifiers** define *what* to look for. Purview ships 150+ **built-in SITs** (credit card, SSN/national ID, IBAN, health record numbers, etc.), and you can add **custom SITs** (regex + keyword + confidence), **Exact Data Match (EDM)** SITs (matched against a hashed upload of your real data for near-zero false positives), and **trainable classifiers** (machine-learned categories such as source code, resumes, or financial statements).

1. **A OneDrive DLP policy** binds those SITs to the **OneDrive accounts** location with **conditions** (which SIT, how many instances, what confidence — and, crucially for OneDrive, *how the file is shared*: **content is shared with people outside my organization** vs. **only inside**), **actions** (audit / notify / restrict access / block external access), and **user experience** (policy tips, allow-with-justification, allow-override).

1. **Simulation mode** runs the policy against live OneDrive content and sharing activity and records what *would* have matched — with or without policy tips shown — so you can see the true hit volume and false positives **before** any enforcement. Every policy in this solution starts here.

1. **Tuning** reduces false positives using confidence levels, instance thresholds, supporting keyword evidence, EDM, and exceptions — measured against the simulation results.

1. **Enforcement** turns the tuned policy on (tips / override / restrict / block external share) in a limited **pilot ring** of users, then expands.

1. **Incident/alert handling** — DLP rule matches raise **alerts** in the Purview portal and DLP events flow to **Activity Explorer**; this solution wires the triage, severity, and response workflow so matches are actually acted on.

The two things a OneDrive policy controls

• **Sensitive content at rest** — sensitive data *stored* in OneDrive, regardless of sharing (e.g. a spreadsheet of card numbers in a user's OneDrive). This surfaces exposure even before anyone shares.

• **Risky sharing of sensitive content** — the higher-severity case: a file containing a SIT that is **shared externally** or via **"anyone with the link."** The DLP rule condition *Content is shared from Microsoft 365 → with people outside my organization* lets you act specifically on the over-share, up to **removing external access** while leaving internal collaboration untouched.

The simulate→enforce journey (the core discipline)

> *Define SITs/classifiers → build the OneDrive DLP policy in **SIMULATION** (no user impact) → measure hit volume and false positives in **Activity Explorer / DLP alerts** → **tune** (confidence, instance count, keywords, EDM, sharing condition, exceptions) → re-simulate until false positives are acceptable → enable with **policy tips + allow-override/justification** in a **pilot ring** → validate → expand to enforce (restrict/block external share) across the intended scope → operate (triage alerts, review overrides, re-tune).*

What you can control

• Which SITs/classifiers are in scope and at what **confidence** and **instance count** they trigger.

• Whether the policy acts on **content at rest**, **externally-shared content**, or both.

• Which OneDrive accounts are **included or excluded** (all accounts, or scoped to a pilot-ring group).

• The **action** per data category (audit → tip → justify → restrict → block external access) — set per compliance's determination.

• Whether users get **policy tips**, can **override** with justification, and what the override says.

• The **pilot ring** enforced first, and the simulation dwell time before enforcement.

Limitations (be honest with buyers)

• **Advanced classifiers are licensing-dependent** — DLP for OneDrive and built-in SITs are broadly available, but **custom/Exact Data Match/trainable classifiers** and some capabilities are gated behind **E5 / the E5 Compliance add-on** (some are in preview). This solution flags "verify your licensing/tenant" rather than asserting availability that may differ in your tenant.

• DLP inspects **content it can classify**; strongly encrypted or unrecognized file formats, or content below the confidence/instance threshold, will not match. DLP is one control among several, not a guarantee.

• **DLP acts on sharing, not on the underlying tenant sharing settings.** If your tenant permits "anyone" links broadly, DLP can restrict the *sensitive* over-shares, but tenant-level SharePoint/ OneDrive external-sharing configuration is a complementary control (verify it separately).

• **Some features are in preview** and **portal paths evolve** — paths are cited from Microsoft docs and flagged to verify.

• The **enforced action for a data category is a compliance/legal decision**, not a technical default — this solution configures and proves the control; the determination is deferred.

Naming convention (used in every doc and script)

Every artifact this solution creates uses `<Purpose> – <Scope> – <Stage>`, reused verbatim across the docs, scripts, and the Purview portal. The standard set:

Artifact	Name
Custom sensitive info type	`Customer PII – Custom SIT – Classification`
EDM schema / SIT	`Customer PII – EDM – Classification`
OneDrive at-rest DLP policy (simulation)	`DLP – OneDrive Sensitive – Simulation`
OneDrive external-share DLP policy (simulation)	`DLP – OneDrive External Share – Simulation`
Enforced pilot policy	`DLP – OneDrive – Enforce Pilot`
Pilot user ring	`DLP OneDrive Pilot Ring – Stage1`
Policy-tip / override text	`DLP Notice – OneDrive – Standard`
Incident/alert workflow	`DLP Alerts – OneDrive – Triage`

The standard deployment model

> ***Assess*** *current OneDrive exposure and classification intent →* ***Design*** *SITs/classifiers, the policy, and the user experience →* ***Configure*** *the policy* ***in simulation*** *→* ***Pilot*** *(simulate → tune → enforce to a ring) →* ***Validate*** *against pass/fail gates (sensitive over-shares restricted, false-positive rate low, incidents handled) →* ***Expand*** *to the full intended scope and ongoing operations. Every high-impact change is piloted in simulation first, with a documented rollback.*

2. Requirements — OneDrive for Business DLP (Microsoft Purview)

These are the **solution-specific** prerequisites for implementing Purview DLP for OneDrive for Business. They build on — and do not repeat — the six shared prerequisites in `global-requirements-purview.md` (tenant + compliance licensing, least-privilege Purview roles, S&C PowerShell + Graph toolchain, in-scope data sources, compliance/records/privacy/legal stakeholders, and a pilot scope + change control). Verify each item below before starting the Implementation Guide.

For every requirement: **Description** (what it is), **Why required**, **How to verify**, **How to implement if missing**.

2.1 Licensing sufficient for the DLP features you will use

• **Description:** DLP for **OneDrive** and **built-in SITs** is broadly available across Microsoft 365

compliance plans, but **custom classifiers**, **Exact Data Match (EDM)**, and **trainable classifiers** are **plan-gated** — typically **Microsoft 365 E5** or the **E5 Compliance** add-on (some capabilities are in **preview**). This extends GR-#1 with the DLP-specific plan detail.

• **Why required:** A policy that relies on a classifier your plan doesn't include will not function.

Basing detection on built-in SITs keeps the initial rollout inside broadly-available capability.

• **How to verify:** In the **Microsoft 365 admin center** confirm the subscription/add-ons; in the

Purview portal → **Data Loss Prevention** → **Policies** → **Create policy** confirm the **OneDrive accounts** location and the classifier types you intend to use are visible. **Flag "verify your licensing/ tenant"** — availability evolves.

• **How to implement if missing:** Acquire/assign the required licensing (E5 or E5 Compliance) before

building custom-classifier/EDM policies; scope the initial rollout to built-in SITs your plan covers.

2.2 DLP-specific least-privilege roles

• **Description:** The **DLP role groups** in the Purview portal — **Compliance Administrator** or

Compliance Data Administrator to create/manage DLP policies, **DLP Compliance Management** for policy management, **View-Only DLP Compliance Management** for read-only review, and the **Data Loss Prevention** role for alert/incident handling. Global Administrator only where genuinely required. Extends GR-#2.

• **Why required:** Purview enforces fine-grained role groups; DLP configuration and alert triage require

the matching role, and least privilege keeps the blast radius small.

• **How to verify: Purview portal** → **Settings** → **Roles & scopes** → **Permissions** (Microsoft Purview

roles) — confirm your account's role-group membership includes the DLP roles you need.

• **How to implement if missing:** Assign the least-privilege DLP role group under change control;

separate policy authors from alert triagers where possible.

2.3 OneDrive provisioned and the sharing posture understood

• **Description:** OneDrive for Business must be **provisioned** for the in-scope users, and you should

know the tenant's current **external-sharing posture** for OneDrive (SharePoint admin / OneDrive sharing settings: Anyone / New and existing guests / Existing guests / Only people in your org). DLP acts on *sensitive* sharing; the tenant setting governs sharing broadly and is a complementary control.

• **Why required:** A OneDrive DLP policy only sees content and shares that actually exist. Knowing the

sharing posture tells you how much external-share risk DLP will surface and whether tenant settings should be tightened alongside DLP.

• **How to verify:** Confirm OneDrive is provisioned for in-scope users; review the OneDrive/SharePoint

external-sharing setting (SharePoint admin center → Policies → Sharing, or via SharePoint Online PowerShell / Graph SharePoint settings). The delivered scope/health script reports the DLP-side scope and, where readable, the tenant sharing signal.

• **How to implement if missing:** Provision OneDrive for the target users; agree the intended external-sharing posture with stakeholders (tenant-setting change is a separate, change-controlled action from the DLP policy).

2.4 A classification intent and a sensitive-information-type inventory

• **Description:** A documented view of **what sensitive data you are protecting** in OneDrive (e.g. payment card data, national IDs, health identifiers, customer PII) mapped to the **SITs/classifiers** that detect it — built-in SITs where they fit, **custom SITs / EDM / trainable classifiers** where they don't. Extends GR-#4.

• **Why required:** DLP policies key off SITs; without knowing which data matters and which SIT detects it (at what confidence and instance count), policies are guesswork and generate false positives.

• **How to verify: Purview portal** → **Data classification** → **Classifiers** → **Sensitive info types** lists built-in and custom SITs; confirm the ones you need exist (or are planned). Confirm the data categories with the data owners.

• **How to implement if missing:** Build the SIT inventory (this solution's Discovery script assesses built-in vs. custom SIT coverage); plan custom SITs / EDM / trainable classifiers for categories not covered.

2.5 Source data for Exact Data Match (only if EDM is used)

• **Description:** For **EDM** SITs, a **sensitive data table** (e.g. an export of customer records) and a workstation with the **EDM Upload Agent** to hash and upload it — the raw data never leaves your control; only salted hashes are uploaded.

• **Why required:** EDM matches against *your actual data*, which is what drives false positives to near zero — but it requires the schema, the hashed upload, and a **refresh cadence** as the data changes.

• **How to verify:** Confirm the source table, the EDM schema, the upload-agent host, and a scheduled refresh. **Purview portal** → **Data classification** → **Exact data matches** shows configured EDM schemas.

• **How to implement if missing:** Define the EDM schema and refresh process (deferred to the data owner for *which* fields are in scope); if EDM is not in your plan or not needed, use custom SITs with confidence/keyword tuning instead.

2.6 A pilot ring, simulation dwell time, and change control (DLP-specific)

• **Description:** A named **pilot user ring** (a mail-enabled security group of OneDrive users), an agreed **simulation dwell time** (how long the policy runs in simulation before enforcement — long enough to capture representative content and sharing activity), and the **change-control window** for moving simulation → enforce. Extends GR-#6.

• **Why required:** DLP is high-impact; enforcing without a simulation baseline and a limited ring is how

DLP breaks legitimate collaboration. The house model mandates **simulation first**, then a ring, then expand.

- **How to verify:** Confirm the pilot-ring group membership, that **simulation mode** is selected on the new policy, and the approval path to enforce.
- **How to implement if missing:** Define the ring (`DLP OneDrive Pilot Ring – Stage1`) and dwell time and agree change control before enabling any enforcement action.

2.7 An incident/alert triage owner and destination

- **Description:** A named owner (or queue) for **DLP alerts** raised in **Purview portal → Data loss prevention → Alerts**, plus where DLP events are reviewed (**Activity Explorer**) and, optionally, where they are forwarded (SIEM/Microsoft Sentinel via the Office 365 Management Activity API / Defender connectors). Severity and response actions defined.
- **Why required:** A DLP match with no one to triage it is not a control. Alerts and Activity Explorer are where matches surface; someone must own triage, severity, and response.
- **How to verify:** Confirm the triage owner/queue (`DLP Alerts – OneDrive – Triage`), the alert-severity scheme, and any SIEM forwarding is configured.
- **How to implement if missing:** Assign the owner, define severity/response, and (optionally) wire SIEM forwarding before enforcement generates real alerts.

Requirements summary

#	Requirement	Gate
GR 1–6	Category prerequisites (`global-requirements-purview.md`)	Tenant/licensing, roles, toolchain, scope, stakeholders, pilot + change control
2.1	DLP/classifier licensing (E5 / E5 Compliance for custom/EDM/trainable; verify)	Chosen classifiers available
2.2	DLP least-privilege roles	Author + triage roles assigned
2.3	OneDrive provisioned + sharing posture understood	Policy has content/shares to act on
2.4	Classification intent + SIT inventory	Policy keys off correct SITs
2.5	EDM source data + agent (if used)	Near-zero-FP matching where needed
2.6	Pilot ring + simulation dwell + change control	Simulate-first enforced

#	Requirement	Gate
2.7	Alert/incident triage owner + destination	Matches are acted on

> ***Deferred to compliance/privacy/legal:*** *which data categories are in scope, which classifiers legally apply, the enforced action per category (e.g. block external sharing vs. warn-and-override), and any regulatory applicability. This solution provides the technical configuration and evidence, not the determination.*

Global Requirements — Microsoft Purview Solutions

These requirements apply to **every** solution in the **Purview** category (implementing and managing Microsoft Purview, sensitivity & retention labels, DLP, data lifecycle & records, insider risk, communication compliance, audit, data security posture management, and data governance). Verify each before starting a solution's implementation steps.

> ***Vendor boundary (applies to every Purview solution).*** *The **Microsoft Purview portal** (purview.microsoft.com), the **Microsoft 365 admin center**, **Security & Compliance PowerShell** (`Connect-IPPSSession`), and **Microsoft Graph** are authored at exact, current click-by-click / cmdlet detail from Microsoft's public documentation. Microsoft Purview features are heavily **licensing-/plan-dependent** (many require **Microsoft 365 E5** or the **E5 Compliance** add-on; some are in preview) and the portal is **actively evolving** — capability availability and portal paths are **cited or flagged "verify your licensing/tenant"**, never asserted or invented. **Regulatory, records-retention, and legal determinations** (retention schedules, records file plans, legal holds, insider-risk case actions, regulatory applicability) are **deferred to the organization's compliance, records, privacy, and legal functions** — the solutions provide the technical configuration method and evidence, not the determination. Automation is **PowerShell** (Security & Compliance PowerShell / Graph) — never with hardcoded credentials or secrets.*

1. Microsoft 365 tenant with the required Purview/compliance licensing

• **Description:** A Microsoft 365 tenant with the **compliance licensing** the capability requires (E3 for baseline; **E5 / E5 Compliance** for advanced DLP, auto-labeling, insider risk, communication compliance, Audit Premium, DSPM, etc.).

• **Why required:** Most Purview capabilities are plan-gated; the feature won't be available without the right plan.

• **How to verify:** In the M365 admin center confirm the subscription/add-ons; check the feature is visible in the Purview portal.

• **How to implement if missing:** Assign/purchase the required licensing before starting.

2. Purview roles (least-privilege) and portal access

• **Description:** Access with the least-privilege **Purview / compliance role** the solution names

(e.g. Compliance Administrator, Compliance Data Administrator, Information Protection, Records Management, Insider Risk, eDiscovery, Audit roles), with Global Administrator only where required.

- **Why required:** Purview uses fine-grained role groups; configuration requires the matching role.
- **How to verify:** Purview portal → **Roles & scopes / Permissions** — confirm the role membership.
- **How to implement if missing:** Assign the least-privilege role group under change control.

3. Security & Compliance PowerShell + Graph toolchain

- **Description:** A workstation with **Security & Compliance PowerShell** (`Connect-IPPSSession` via the

ExchangeOnlineManagement module) and **Microsoft Graph PowerShell**, modern-auth / MFA-capable admin.

- **Why required:** Configuration, automation, and the provided scripts run through these.
- **How to verify:** `Connect-IPPSSession` and `Connect-MgGraph` succeed with the admin account.
- **How to implement if missing:** Install the modules and confirm modern-auth sign-in before running steps.

4. Data sources & scope in scope

- **Description:** The **workloads and data sources** in scope (Exchange, SharePoint, OneDrive, Teams,

endpoints/devices, and — for data governance — the broader data estate) and a **data-classification / sensitivity** intent to drive labels, DLP, and retention.

- **Why required:** Purview policies key off the in-scope workloads and the classification scheme.
- **How to verify:** Confirm the in-scope workloads and the classification/sensitivity approach with

stakeholders.

- **How to implement if missing:** Define the scope and classification intent before authoring policies.

5. Compliance, records, privacy & legal stakeholders

- **Description:** Engagement with the **compliance, records-management, privacy, security, and legal**

stakeholders whose policies the configuration must satisfy (retention schedules, records file plans, regulatory obligations, insider-risk and communication-compliance policy, legal hold).

- **Why required:** Purview configuration must align to enterprise policy and legal/records requirements,

not technical defaults; several capabilities have HR/legal sensitivity.

- **How to verify:** Confirm the applicable policies, the records schedule, and named approvers.
- **How to implement if missing:** Identify the owners and capture the requirements before configuring.

6. A pilot scope and change control

• **Description:** A **pilot scope** (users/sites/policies in simulation or a limited ring) to validate

on before tenant-wide enforcement, and a **change-control** process — most Purview policies support a **simulation / test / disabled** mode that MUST be used before enforcement.

• **Why required:** Every solution follows an **Assess → Design → Configure → Pilot (simulate) → Validate

→ Expand (enforce)** model; DLP, labels, retention, and insider-risk changes are high-impact.

• **How to verify:** Confirm a named pilot scope, that simulation/test mode is available, and a change

window/approval path.

• **How to implement if missing:** Define the pilot and agree change control before enforcing anything.

*The deployment model across every Purview solution is the same: **Assess** → **Design** → **Configure** → **Pilot (simulate/test)** → **Validate** → **Expand (enforce)**, with explicit pass/fail gates and a documented rollback. Automation is delivered as **PowerShell** (Security & Compliance PowerShell / Graph) — never with hardcoded credentials or secrets. Regulatory/records/legal determinations are deferred to the relevant governance functions.*

3. Implementation Guide — OneDrive for Business DLP (Microsoft Purview)

This is the exact, ordered procedure to implement Purview DLP for **OneDrive for Business** — the policy built in **SIMULATION** first, tuned, then enforced in a pilot ring, then expanded. Portal paths and cmdlets are from Microsoft's public documentation; **licensing-/plan-dependent features and evolving portal paths are flagged "verify your licensing/tenant"** and are never asserted for your tenant. Do the phases in order. Each phase names its artifacts (from the Overview naming table), states a **pass/fail gate**, and gives a **rollback**.

> ***Automation.*** *The five delivered PowerShell tools run through **Security & Compliance PowerShell** (`Connect-IPPSSession`) and **Microsoft Graph**. They are **read-only or** `-WhatIf` **by default**; writes require an explicit `-Commit` switch, and the config helper never leaves a policy in enforce mode. No credentials are stored in code.*
>
> ***Determinations deferred.*** **Which* data categories are in scope, *which* classifiers legally apply, and the *enforced action* per category (e.g. remove external access vs. warn-and-override) are **compliance/privacy/legal** decisions. This guide configures and proves the control; capture those decisions before Phase 4.*

Phase 0 — Connect and baseline (Assess)

1. **Connect the toolchain** (GR-#3). On the admin workstation:

```
Install-Module ExchangeOnlineManagement -Scope CurrentUser -Force   # provides Connect-IPPSSession
Connect-IPPSSession -UserPrincipalName admin@contoso.com            # Security & Compliance PowerShell
Connect-MgGraph -Scopes 'Organization.Read.All' -NoWelcome         # optional signals
```

1. **Run the posture assessment** (delivered script #1, read-only):

```
.\DLPOD-Discovery.ps1 -CsvPath .\DLPOD-Posture.csv
```

It reports existing DLP policies that touch **OneDrive** and their mode, built-in vs. custom SIT coverage, and any EDM schemas — so you build on top of what exists rather than duplicating it.

1. **Understand the OneDrive sharing posture** (Req 2.3): run the scope/health helper to see the DLP-side

OneDrive scope and, where readable, the tenant external-sharing signal:

```
.\DLPOD-Scope.ps1
```

Pass/fail gate: you have a written baseline (existing OneDrive-touching policies + modes), a SIT coverage map, and an understanding of the current external-sharing posture. **Rollback:** none (read-only).

Phase 1 — Design the classification layer (SITs & classifiers)

Decide, per in-scope data category, which detector applies. Do **not** invent SITs — use built-in where they fit; build custom/EDM/trainable only for gaps.

1. **Map built-in SITs first.** In **Purview portal → Data classification → Classifiers → Sensitive info

types**, confirm the built-in SITs for your categories (e.g. *Credit Card Number*, *U.S. Social Security Number (SSN)*, *ABA Routing Number*, national-ID SITs). Note each SIT's** confidence levels **and default** instance count**.

1. **Author custom SITs for gaps.** For a category with no built-in match (e.g. an internal customer

reference), create `Customer PII – Custom SIT – Classification` with a **regex primary pattern**, **supporting keywords**, a **confidence level**, and a **character proximity**. Portal: **Classifiers → Sensitive info types → Create sensitive info type**. Test it against sample text in the wizard's **Test** step.

1. **Configure EDM only where near-zero false positives are required** (Req 2.5). Define the schema

(`Customer PII – EDM – Classification`), hash-and-upload the source table with the **EDM Upload Agent**, and set a **refresh cadence**. Portal: **Data classification → Exact data matches**. *Which fields are in scope is the data owner's determination.*

1. **Add trainable classifiers where a category is conceptual, not pattern-based** (e.g. source code,

resumes) — use a built-in trainable classifier or train a custom one on sample content. Verify availability against your plan.

Pass/fail gate: every in-scope data category maps to a named, tested SIT/classifier at a chosen confidence and instance count. **Rollback:** delete unused custom SITs/EDM schemas (they have no effect until referenced by a policy).

Phase 2 — Build the OneDrive DLP policy in SIMULATION (Configure — no user impact)

Create the OneDrive policy in **simulation mode**. Simulation evaluates the policy against real OneDrive content and sharing activity and records what *would* match, with **no** enforcement and (optionally) with policy tips shown. Build **two rules** (or two policies) so at-rest exposure and risky sharing are handled distinctly.

1. **At-rest sensitive-content rule — policy** `DLP – OneDrive Sensitive – Simulation`**.**

Portal: **Data loss prevention** → **Policies** → **Create policy** → custom or a category template → **Locations: OneDrive accounts only** → rule: condition *Content contains* the SITs from Phase 1 at the chosen **confidence** and **instance count** → action *Restrict access or encrypt the content* (kept inert by simulation) → **Policy mode: Run the policy in simulation mode** (optionally *with policy tips*). Finish. This surfaces sensitive data stored in OneDrive regardless of sharing.

1. **External-share rule — policy** `DLP – OneDrive External Share – Simulation`**.**

Same flow → **Locations: OneDrive accounts** → rule conditions: *Content contains* the SITs **AND** *Content is shared from Microsoft 365* → **with people outside my organization** → action *Restrict access or encrypt* → set **Restrict access** to *Block only people who were given access to the content through the "Anyone with the link" option* (or *block external users*), per compliance's determination → **simulation mode**. This targets the high-severity over-share specifically, leaving internal collaboration untouched.

1. **Set the user experience** consistently: define `DLP Notice – OneDrive – Standard` policy-tip text

and enable **allow override with justification** where compliance permits — but note tips/overrides only *appear* once a policy is enforced; in simulation they are captured, not shown to end users unless "simulation with policy tips" is selected.

1. **Verify/author with the config helper** (delivered script #2, `-WhatIf` by default):

```
.\DLPOD-Config.ps1 -PolicyName 'DLP – OneDrive Sensitive – Simulation' `
    -SensitiveTypes 'Credit Card Number' -MinCount 10 -Confidence High -WhatIf
# external-share variant:
.\DLPOD-Config.ps1 -PolicyName 'DLP – OneDrive External Share – Simulation' `
    -SensitiveTypes 'Credit Card Number' -MinCount 1 -Confidence High -ExternalShareOnly -WhatIf
```

Run with `-Commit` only to apply an intended change; the script creates the policy in **simulation** and never leaves a policy in enforce mode.

Pass/fail gate: both policies exist and are confirmed in **simulation** (script #1/#2 report `Mode = TestWithNotifications / TestWithoutNotifications`), scoped to **OneDrive accounts** with the correct SITs and (for the external-share policy) the outside-org sharing condition. **Rollback:** delete the simulation policy — simulation has no user impact, so removal is clean.

Phase 3 — Measure and tune (drive false positives down)

Let each policy run in simulation for the agreed **dwell time** (Req 2.6) to capture representative OneDrive content and sharing activity.

1. **Review what matched. Purview portal** → **Data loss prevention** → **Alerts** (simulation alerts) and

Data classification → **Activity explorer** (filter to DLP activities, OneDrive workload) show every simulated match with the file, the SIT, the confidence, and the sharing state. Export with the reporting script:

```
.\DLPOD-Report.ps1 -Days 14 -CsvPath .\DLPOD-Matches.csv
```

1. **Classify each match** as true positive or **false positive** and identify the false-positive

drivers (e.g. a built-in *Credit Card* SIT firing on internal reference numbers).

1. **Tune** to reduce false positives without losing true positives:

• Raise the **confidence level** (e.g. medium → high) so only high-confidence matches count.

• Raise the **instance count** for the at-rest rule (e.g. require ≥10 card numbers) for bulk-leak focus; keep the external-share rule sensitive (even a single instance shared externally matters).

• Add **supporting keywords / proximity** to custom SITs so context is required.

• Introduce **EDM** for categories where pattern SITs over-match.

• Add **exceptions** (e.g. exclude a specific internal service account/site) where justified.

1. **Re-simulate** after each tuning change and re-measure. Repeat until the false-positive rate meets the validation gate (see Testing).

Pass/fail gate: measured false-positive rate is at/under the agreed threshold on the simulation sample, with true positives (including external over-shares) still detected. **Rollback:** revert the last tuning change (script #2 `-WhatIf` shows the intended change before `-Commit`).

Phase 4 — Enforce in a pilot ring (Pilot)

1. **Scope to the pilot ring.** Set `DLP OneDrive Pilot Ring – Stage1` as the **included** OneDrive scope on each policy (all other accounts excluded for now) using the scope helper:

```
.\DLPOD-Scope.ps1 -PolicyName 'DLP – OneDrive External Share – Simulation' `
    -PilotRingGroup 'DLPOneDrivePilotRing@contoso.com' -Commit
```

1. **Move the ring to enforcement.** In the portal, change **Policy mode** from *simulation* to **Turn it on / Enforce**. Start with** policy tips + allow-override (justification)** rather than hard restrict, so the pilot can report false negatives/positives while retaining a business escape hatch.

1. **Confirm enforcement is live** for the ring only (script #1 reports mode `Enable` and the scoped identities). Confirm a ring user sees the `DLP Notice – OneDrive – Standard` tip when they store or externally share a test match (use fake test data — see Testing).

1. **Handle incidents.** Wire `DLP Alerts – OneDrive – Triage`: assign the alert owner/queue (Req 2.7), set severities, and (optionally) forward to SIEM/Sentinel. Triage a real simulated/pilot alert end-to-end to prove the workflow.

Pass/fail gate: the pilot ring is enforced (tips shown, overrides captured, external over-shares restricted), matches raise alerts, and the triage workflow produces a dispositioned incident. No enforcement outside the ring. **Rollback:** set the policy back to **simulation mode** (single setting) — instantly removes enforcement with no data change.

Phase 5 — Expand and harden (Enforce → Operate)

1. **Expand scope** from the ring to the full intended OneDrive population once the pilot gate passes, keeping documented exclusions.

1. **Escalate the action** per compliance's determination — e.g. move the external-share rule from *tip

+ override* to **block external access** (remove "anyone" links / external users), one step at a time, re-validating after each.

1. **Operationalize:** schedule the reporting script for a recurring false-positive/alert review, review

user overrides (are people justifying legitimately or bypassing?), refresh **EDM** data on cadence, and re-tune as content and sharing behavior change. Consider tightening the tenant OneDrive external-sharing setting alongside DLP (Req 2.3) as a complementary, change-controlled action.

1. **Validate end-to-end** with the delivered testing procedure (next section) and record the pass/fail

evidence:

```
.\DLPOD-Validate.ps1 -CsvPath .\DLPOD-Validation.csv
```

Pass/fail gate: enforcement live across the intended scope with the compliance-mandated action per category; false-positive rate steady/low; alerts triaged on cadence; overrides reviewed. **Rollback:** any policy can be returned to **simulation** at any time as an immediate, non-destructive safety switch; the at-rest and external-share policies can be disabled independently.

Order-of-operations summary

Phase	Do	Artifact(s)	Gate	Rollback
0 Assess	Connect, baseline, read sharing posture	Posture CSV	Baseline + posture understood	n/a (read-only)
1 Design	Map/build SITs, EDM, classifiers	Custom SIT / EDM schema	Every category → tested detector	Delete unused SIT/EDM
2 Configure	Build at-rest + external-share policies in **simulation**	Two OneDrive sim policies	Both in simulation, correct scope/conditions	Delete sim policy
3 Tune	Measure + reduce false positives	Matches CSV	FP rate ≤ threshold, over-shares still caught	Revert tuning change
4 Pilot	Enforce to ring, wire alerts	Pilot ring, alert triage	Ring enforced, incident dispositioned	Back to simulation
5 Expand	Broaden scope, escalate to block, operate	Enforced policies	Full-scope enforce, low FP, alerts triaged	Simulation / disable

5. Testing & Validation — OneDrive for Business DLP (Microsoft Purview)

Validate the OneDrive DLP implementation against explicit **pass/fail gates**. The three headline gates for this solution are: **(A) sensitive content and risky shares are caught**, **(B) the false-positive rate is low**,

and **(C) incidents are handled**. Run every test with **non-real, clearly-fake sample data** (e.g. the Microsoft-documented test credit-card number `4111 1111 1111 1111`) — never real customer/employee data — and record the evidence.

> *All tests assume the policies from the Implementation Guide, first proven in **simulation** and then enforced to the **pilot ring** (`DLP OneDrive Pilot Ring – Stage1`).*

Test A — Detection & enforcement (sensitive content and risky shares are caught)

#	Test	Steps	Pass condition
A1	At-rest sensitive content	As a pilot-ring user, upload a file to OneDrive containing enough fake SIT instances to meet the at-rest threshold.	Match recorded (simulation) or restricted (enforced) per the `DLP – OneDrive Sensitive` policy; event appears in Activity Explorer (OneDrive workload).
A2	External "anyone with the link" share	As a ring user, share a file containing the fake SIT with an **"anyone with the link"** option.	The `DLP – OneDrive External Share` rule matches; per enforced action the anyone-link/external access is restricted; a DLP alert is raised.
A3	External direct share	Share the fake-SIT file directly to an **external** email address.	Rule matches on *shared with people outside my organization*; external access restricted per policy; event logged.
A4	Internal share negative	Share the fake-SIT file **only with an internal colleague** (no external link).	External-share rule correctly does **not** restrict — internal collaboration is untouched (at-rest rule may still record the content).
A5	Policy tip shown	On an enforced ring account, trigger A1/A2.	The `DLP Notice – OneDrive – Standard` policy tip is shown to the user; override-with-justification is offered where configured.

#	Test	Steps	Pass condition
A6	Below-threshold negative	Store content with **fewer** SIT instances than the at-rest threshold (or lower confidence).	Correctly **not** matched by the at-rest rule — confirms the threshold/confidence tuning holds.

Gate A (pass): A1–A3 each produce the enforced action and a logged event; A4 and A6 correctly do **not** restrict; A5 shows the tip/override.

Test B — False-positive rate (adoption gate)

#	Test	Steps	Pass condition
B1	Simulation FP baseline	Over the agreed dwell time, export simulation matches (`DLPOD-Report.ps1 -Days <n>`) and classify each as TP/FP.	**False-positive rate** ≤ **the agreed threshold** (define with compliance; a common target is ≤10% of matches, or an absolute FP count the triage team can absorb).
B2	Legitimate-traffic negative	Store and share representative legitimate business content (no real sensitive data) in a ring account.	Legitimate content is **not** matched/restricted — no spurious tips or blocked shares.
B3	Post-tuning re-measure	After each tuning change (confidence↑, instance count↑, keywords, EDM, exceptions), re-simulate and re-measure.	FP rate trends **down** while true positives (Test A) still fire.
B4	Override sanity	In the pilot ring, review captured **allow-with-justification** overrides.	Overrides are legitimate business justifications, not routine bypass — if routine, re-tune or re-scope.

Gate B (pass): measured FP rate at/under threshold on the simulation sample with true positives (including external over-shares) intact.

Test C — Incident / alert handling (the control is operable)

#	Test	Steps	Pass condition
C1	Alert raised	Trigger a policy match (Test A1/A2).	A DLP **alert** appears in **Purview** → **Data loss prevention** → **Alerts** with the correct policy, severity, and evidence.
C2	Triage workflow	The `DLP Alerts – OneDrive – Triage` owner/queue picks up the alert, sets status, and dispositions it.	Alert moves through the defined states to a resolved disposition by the named owner.
C3	Activity Explorer trail	Locate the same event in **Data classification** → **Activity explorer** (OneDrive workload).	Full evidence trail present (user, file, SIT, sharing state, action) for investigation.
C4	SIEM forwarding (if configured)	Confirm the DLP event reaches the SIEM/Sentinel destination (Req 2.7).	Event present in the downstream system with usable fields.

Gate C (pass): matches raise alerts, alerts are triaged to disposition by the owner, and the evidence trail (and SIEM forward, if used) is present.

Simulation-first & rollback validation

#	Test	Pass condition
S1	Nothing enforced outside the ring	Accounts **outside** `DLP OneDrive Pilot Ring – Stage1` experience no restriction during pilot.
S2	Instant rollback	Setting any enforced policy back to **simulation mode** immediately removes enforcement with no data change (verify a previously-restricted external share now only simulates).
S3	Scripts are safe-by-default	`DLPOD-Config.ps1` / `DLPOD-Scope.ps1` run **without** `-Commit` make no change (`-WhatIf` output only); discovery/report/validate scripts are read-only.

Evidence to capture (for the deliverable record)

• Baseline posture CSV (Phase 0) and the SIT coverage map.

• Simulation match export + TP/FP classification and the computed **false-positive rate** before/after tuning (Gate B).

• Screenshots/log of Test A enforcement actions (at-rest match + external-share restriction) and the raised alerts (Gate A/C).

• The dispositioned incident from Test C2 and, if used, the SIEM forward (C4).

• Confirmation that outside-ring accounts were unaffected (S1) and that simulation rollback works (S2).

• The `DLPOD-Validate.ps1` output summarizing the OneDrive policy modes, scope, and readiness signals.

> ***Determination boundary.*** *These tests prove the **control works**. Whether a given category's enforced action (e.g. block external sharing outright) and FP threshold are *acceptable* is a compliance/privacy/legal sign-off, captured alongside the evidence above.*

6. Troubleshooting — OneDrive for Business DLP (Microsoft Purview)

Symptom-first fixes for the failures you actually hit implementing DLP for OneDrive. Most problems are one of: a policy not matching, the *shared-externally* condition not firing, too many false positives, or matches that raise no alert.

Policy / detection

A OneDrive DLP policy matches nothing even though the content clearly contains sensitive data.

• Confirm the policy is actually **enabled and in a mode that evaluates** — a *disabled* policy does nothing; a **simulation** policy evaluates and logs but does not restrict. Check with `DLPOD-Discovery.ps1` (Mode column) or `DLPOD-Validate.ps1`.

• Confirm the policy actually **targets the OneDrive location** (`OneDriveLocation`) — a policy scoped only to SharePoint/Exchange won't see OneDrive content. `DLPOD-Validate.ps1` flags this.

• Check the **instance count and confidence** on the rule — if it requires ≥10 matches at High confidence and your test has 1, it correctly won't fire. Lower the threshold for testing, or add more sample instances.

• **Policy propagation takes time** — newly created/changed DLP policies can take **up to ~1 hour (and longer for some content)** to take effect, and OneDrive content is scanned on a crawl cycle. Wait before concluding it's broken.

• Confirm the target account isn't in an **exclusion** and, if you scoped a pilot ring (`OneDriveSharedByMemberOf`), that the test user is in that group.

A custom SIT never matches.

• Test the SIT's **regex + keywords** in the SIT wizard's **Test** step with known-matching text. A too-strict regex, wrong **character proximity**, or a required keyword that isn't present will suppress all matches. Loosen and re-test incrementally.

Matches appear in simulation but nothing is restricted.

• That is **correct** — simulation logs what *would* happen without enforcing. To restrict, move the policy to **enforce** for the pilot ring (Implementation Phase 4). If you expected restriction, you're still in simulation.

External-share condition

The external-share rule doesn't fire when I share a sensitive file.

• Confirm the rule carries the **AccessScope = NotInOrganization** condition (the *shared with people outside my organization* condition) — `DLPOD-Validate.ps1` reports this as `ExternalShareScope`. If it reads False, the rule is an at-rest rule only.

• Confirm the share is genuinely **external** — an internal-only share (or a link restricted to specific internal people) correctly does **not** match the outside-org condition.

• **"Anyone with the link"** shares depend on the **tenant permitting anonymous links**. If the tenant sharing setting blocks anonymous links entirely, the anyone-link path may not be exercisable to test — test with an external guest share instead. Check the sharing signal with `DLPOD-Scope.ps1`.

• Allow for **evaluation latency** — the sharing event must be processed before the rule acts.

DLP isn't stopping "anyone" links even in enforce mode.

• DLP acts on **sensitive** shares matched by the rule; a share of non-sensitive content is out of scope by design. Broad control over anonymous links is a **tenant sharing setting** (SharePoint admin center → Policies → Sharing), complementary to DLP (Req 2.3) — tighten it there if you need a blanket limit.

False positives (the adoption killer)

Users are getting policy tips on legitimate, non-sensitive content.

• Export matches with `DLPOD-Report.ps1 -CsvPath ...`, classify TP/FP, and identify the driver.

• **Raise confidence** (medium→high) and/or **instance count** on the at-rest rule so single/low-confidence hits don't fire. (Keep the external-share rule sensitive — even one instance shared out matters.)

• Add **supporting keywords/proximity** to custom SITs so context is required.

• For a built-in SIT that over-matches your internal identifiers, move that category to **Exact Data Match** so only your real data matches.

• Add a targeted **exception** where justified (specific internal service account/site) — narrowly, with a documented reason.

- Re-simulate after each change and re-measure — don't stack multiple changes blind.

Alerts / incident handling

Policy matches occur but no alert appears / no one is notified.

- Confirm **alerts are configured** on the rule (alert on match, threshold) and check **Purview → Data loss prevention → Alerts**. Some low-severity matches aggregate rather than alert per event.
- Confirm **audit logging is enabled** in the tenant — the report script and Activity Explorer rely on it.
- Confirm the **triage owner/queue** (`DLP Alerts – OneDrive – Triage`) exists and, if forwarding to SIEM/Sentinel, that the connector is healthy (Req 2.7).

The report script returns no matches.

- **Audit log latency:** DLP events can take time to appear; widen `-Days` and re-run.
- Freshly created policies need **dwell time** — there may simply be no matches yet, and OneDrive content is scanned on a crawl cycle.
- Confirm **audit logging is on** and your account has the **View-Only DLP / audit** role.

Connectivity / tooling

`Connect-IPPSSession` **or a DLP cmdlet fails.**

- Ensure the **ExchangeOnlineManagement** module is installed/updated and you're using a **modern-auth / MFA-capable** admin.
- Confirm the account holds the required **DLP role** (Compliance Administrator / Compliance Data Administrator / DLP Compliance Management) — a missing role surfaces as "cmdlet not recognized" or access denied.

The sharing signal in `DLPOD-Scope.ps1` **is blank / skipped.**

- The tenant sharing signal is read from **Microsoft Graph** (`/admin/sharepoint/settings`) and needs the **SharePointTenantSettings.Read.All** scope; the script **skips it gracefully** if Graph isn't connected or the scope isn't consented. Verify the setting directly in the SharePoint admin center (Policies → Sharing) — it is context only, not required for the DLP policy to work.

A script made an unexpected change.

- The delivered scripts are **read-only or** `-WhatIf` **by default**; writes require `-Commit`. If a change landed, it was committed intentionally — the config helper never leaves a policy in **enforce**, so the safe recovery is always to set the policy back to **simulation** in the portal (one setting, no data change).

Fast triage table

Symptom	First check
Policy matches nothing	Mode (disabled/sim), OneDrive targeted, instance count/confidence, propagation time, scope/exclusion
Custom SIT never fires	Test regex+keywords+proximity in the SIT wizard
Nothing restricted	Still in **simulation** — that's expected; enforce the ring to restrict
External-share rule not firing	AccessScope=NotInOrganization present, share is truly external, tenant allows the link type
"Anyone" links not stopped	DLP acts on *sensitive* shares; blanket anonymous-link limits are a tenant sharing setting
Too many false positives	Raise confidence/instance count, add keywords/EDM, exceptions, re-simulate
No alert on match	Alert config on rule, audit logging on, triage owner, SIEM connector
Report returns nothing	Audit latency/dwell time, audit logging on, role
Sharing signal blank	Graph scope SharePointTenantSettings.Read.All / check SharePoint admin center
Cmdlet/connect fails	Module updated, modern auth, correct DLP role

7. Best Practices — OneDrive for Business DLP (Microsoft Purview)

Field-tested practices for running Purview DLP for OneDrive so the control stays trusted, effective, and low-noise. These complement the Implementation and Testing guides.

Simulate before you enforce — always

• **Never** switch a new or materially changed OneDrive DLP policy straight to enforce. Run it in **simulation** first, long enough to capture representative content and sharing activity (Req 2.6), and read the results before enabling.

• Use **simulation with policy tips** on the pilot ring when you want end-user feedback before hard restrict.

• Treat **simulation mode as your permanent safety switch**: any enforced policy can be returned to simulation in one setting, instantly removing enforcement with no data change — this is your rollback.

Separate "at rest" from "shared" — act proportionally

• Split the control into an **at-rest** rule (sensitive content stored in OneDrive) and an **external-share** rule (that content shared outside the org). They warrant different thresholds and actions: at-rest is often *audit/notify* with a higher instance count; external over-share is the high-severity case and justifies a **lower threshold and a stronger action**.

• Target the **specific risky share**, not all sharing — use the *shared with people outside my organization* condition so internal collaboration is never disrupted.

• The most valuable single control is usually **restricting sensitive "anyone with the link" shares** — those are the widest-reachable and the least intentional.

Tune for a low false-positive rate (adoption depends on it)

• Start at **higher confidence** and a **realistic instance count** for at-rest matches — a single credit-card match is noise; ten in one file is a leak.

• Add **supporting keywords and proximity** to custom SITs so context is required, not just a pattern.

• Use **Exact Data Match** for categories where pattern SITs over-fire — it matches your *actual* data and drives false positives toward zero, at the cost of an upload + refresh cadence.

• Every false positive that reaches a user erodes trust in **every** policy tip. Budget for a tuning cycle, not a one-time build.

Right-size the user experience

• Show **clear, actionable policy tips** — tell the user *why* and *what to do* ("this file contains card numbers; remove the anyone-link or share internally only"), in business language, not a compliance error code. Reuse one standard notice (`DLP Notice – OneDrive – Standard`).

• Prefer **allow-with-justification / override** over hard restrict for categories where legitimate external sharing exists, then **review the overrides** — routine overriding means the policy is mis-scoped.

• Reserve **block external access** (removing links/external users) for the categories where compliance/legal require it; escalate one category at a time, re-validating each.

Coordinate with tenant sharing settings

• DLP acts on the *sensitive* over-shares; the **tenant OneDrive/SharePoint external-sharing setting** governs sharing broadly. Treat them as complementary — DLP is the content-aware control, the tenant setting is the blunt boundary. Tightening the tenant setting is a separate, change-controlled action.

• Know your current posture (Req 2.3) before enforcing so you can predict how many external over-shares DLP will surface.

Classification hygiene

• **Reuse built-in SITs** wherever they fit; build custom/EDM/trainable only for genuine gaps — fewer, well-tuned detectors beat a sprawl of overlapping ones.

• **Version and document** each custom SIT/EDM schema (pattern, confidence, keywords, owner) so tuning changes are traceable.

• **Refresh EDM data** on a schedule — stale EDM data silently degrades matching.

Operations & governance

• Give DLP **alerts an owner and an SLA** (Req 2.7). Match volume without triage is not a control. Forward to SIEM/Sentinel where central SecOps needs visibility.

• Review **Activity Explorer** and the false-positive rate on a **recurring cadence**; re-tune as content and sharing behavior drift.

• Enforce **least-privilege roles** and, where possible, **separate policy authors from alert triagers**.

• Keep a **change log** of every simulate→enforce transition and every action escalation, with the compliance sign-off attached.

Stay inside the boundary

• DLP is **one control**, not a guarantee — it inspects content it can classify; combine with sensitivity labels, tenant sharing controls, and insider-risk where the risk warrants.

• **Verify licensing/tenant** before relying on any custom/advanced-classifier capability — plans and portal paths evolve; don't assume a feature is present.

• The **enforced action and the acceptable false-positive threshold per category are compliance/legal determinations** — you provide the technical control and the evidence; they own the decision.

8. Deliverables Summary — OneDrive for Business DLP (Microsoft Purview)

What you receive in this solution, and what "done" looks like.

Documentation

Document	What it gives you
Solution Overview	The OneDrive DLP model — SITs/classifiers, the two things a policy controls (sensitive content at rest and risky external sharing), policy tips/overrides, and the simulate→enforce journey; naming convention.

Document	What it gives you
Requirements Guide	Solution-specific prerequisites (DLP/classifier licensing, DLP roles, OneDrive provisioned + sharing posture, classification intent, EDM source data, pilot ring, alert triage owner) each with verify/implement steps, on top of the six category prerequisites.
Implementation Guide	The exact ordered phases: connect/baseline → design SITs → build the at-rest and external-share policies **in simulation** → tune false positives → enforce to a pilot ring → expand; each phase named, gated, and with a rollback.
Testing & Validation	Pass/fail gates for the three headline outcomes — content/shares caught (A), low false-positive rate (B), incidents handled (C) — plus simulation-first and rollback checks, all with fake test data.
Troubleshooting Guide	The common failure modes (policy not matching, external-share condition not firing, floods of false positives, no alerts) and how to resolve them.
Best Practices	Simulate-first discipline, separating at-rest from shared, false-positive tuning, user-experience design, tenant-sharing coordination, classification hygiene, and operations/governance.
Executive Summary	One-page business framing for approvers.

PowerShell tools (5) — Security & Compliance PowerShell / Graph

All tools are **read-only or `-WhatIf` by default**; writes require an explicit `-Commit`. No credentials are stored in code. They connect via `Connect-IPPSSession` and/or `Connect-MgGraph`.

#	Script	Role	Default safety
1	**DLPOD-Discovery.ps1**	OneDrive DLP posture + sensitive-info-type coverage assessment: existing policies that touch OneDrive and their mode, built-in vs. custom SIT coverage, EDM schemas.	Read-only

#	Script	Role	Default safety
2	**DLPOD-Config.ps1**	OneDrive DLP policy configuration/remediation helper: creates/updates a policy **in simulation mode** (optionally with the *shared externally* condition via `-ExternalShareOnly`) and reports the intended change.	`-WhatIf` (writes need `-Commit`; never leaves a policy in enforce)
3	**DLPOD-Validate.ps1**	Validation reporter: checks the OneDrive policies' mode, location scope, and sharing conditions against the expected pass/fail gates and emits a validation record.	Read-only
4	**DLPOD-Report.ps1**	DLP match / false-positive tuning report: exports OneDrive simulation/enforcement matches for TP-vs-FP classification and rate calculation.	Read-only
5	**DLPOD-Scope.ps1**	Scope/health helper: reports a policy's OneDrive scope + tenant external-sharing signal and (with `-Commit`) sets the pilot-ring included scope.	`-WhatIf` (writes need `-Commit`)

Definition of done

• Sensitive information types/classifiers mapped for every in-scope data category (built-in reused; custom/EDM/trainable only for gaps).

• OneDrive **at-rest** and **external-share** DLP policies built and **proven in simulation**.

• False-positive rate measured and tuned to at/under the agreed threshold (Gate B).

• Enforcement live for the pilot ring with policy tips + override, then expanded per compliance's action determination — including restricting sensitive external/"anyone" shares (Gate A).

• DLP alerts raised, triaged to disposition, and evidence trailed in Activity Explorer (Gate C).

• Simulation-rollback and safe-by-default scripts verified; change log and compliance sign-offs captured.

Boundary: *the solution delivers the technical control and the evidence. The* ***data categories in scope, the classifiers that legally apply, the enforced action per category (e.g. block external sharing vs. warn-and-override), and the acceptable false-positive threshold*** *are compliance/privacy/ legal determinations, captured alongside the evidence.*

Appendix A — PowerShell Scripts

Included in the accompanying ZIP. Each script's header documents full usage.

DLPOD-Config.ps1

Purpose: Creates a new DLP compliance policy (and a matching content rule for one or more sensitive information types) scoped to the ONEDRIVE location in SIMULATION mode, or updates an existing policy's rule. With -ExternalShareOnly the rule additionally requires the content to be shared with people OUTSIDE the organization (AccessScope NotInOrganization) — the high-severity over-share case. Safe by default: with -WhatIf it only reports the intended change; it applies nothing unless -Commit is passed, and it NEVER creates or leaves a policy in enforce (Enable) mode — simulation only. Enforcement is a deliberate, separate portal/change-control step. HOW TO RUN Preview an at-rest OneDrive simulation policy for the built-in Credit Card SIT: powershell -File .\DLPOD-Config.ps1 -PolicyName 'DLP - OneDrive Sensitive - Simulation' `-SensitiveTypes 'Credit Card Number' -MinCount 10 -Confidence High -WhatIf Preview the external-share variant (fires when shared outside the org): powershell -File .\DLPOD-Config.ps1 -PolicyName 'DLP - OneDrive External Share - Simulation'` -SensitiveTypes 'Credit Card Number' -MinCount 1 -Confidence High -ExternalShareOnly -WhatIf Actually create it (still simulation mode): powershell -File .\DLPOD-Config.ps1 -PolicyName 'DLP - OneDrive Sensitive - Simulation' ` -SensitiveTypes 'Credit Card Number' -MinCount 10 -Confidence High -Commit Requires Security & Compliance PowerShell (Connect-IPPSSession). EXPECTED RESULTS -WhatIf: prints the New-DlpCompliancePolicy / New-DlpComplianceRule calls it WOULD run, with Mode=TestWithNotifications and OneDriveLocation=All. -Commit: creates the policy in simulation and the rule, then prints the resulting Mode (a Test* value = PASS). Verify with DLPOD-Discovery.ps1. .NOTES Purview — OneDrive for Business DLP. Writes gated behind -Commit; simulation-only (never Enable). No credentials in code. > [CmdletBinding()] param([Parameter(Mandatory)][string]$PolicyName, [string[]]$SensitiveTypes = @('Credit Card Number'), [int]$MinCount = 10, [ValidateSet('Low','Medium','High')][string]$Confidence = 'High', When set, the rule also requires the content to be shared OUTSIDE the org (the over-share case). [switch]$ExternalShareOnly, Simulation flavour: with or without showing policy tips to users during the test. [ValidateSet('TestWithNotifications','TestWithoutNotifications')][string]$SimulationMode = 'TestWithNotifications', [string]$UserPrincipalName, [switch]$Commit)

How to run: Preview an at-rest OneDrive simulation policy for the built-in Credit Card SIT: powershell -File .\DLPOD-Config.ps1 -PolicyName 'DLP - OneDrive Sensitive - Simulation' `-SensitiveTypes 'Credit Card Number' -MinCount 10 -Confidence High -WhatIf Preview the external-share variant (fires when shared outside the org): powershell -File .\DLPOD-Config.ps1 -PolicyName 'DLP - OneDrive External Share - Simulation'` -SensitiveTypes 'Credit Card Number' -MinCount 1 -Confidence High -ExternalShareOnly -WhatIf Actually create it (still simulation mode): powershell -File .\DLPOD-Config.ps1 -PolicyName 'DLP - OneDrive Sensitive - Simulation' ` -SensitiveTypes 'Credit Card Number' -MinCount 10 -Confidence High -Commit Requires Security & Compliance PowerShell (Connect-IPPSSession). EXPECTED RESULTS -WhatIf: prints the New-DlpCompliancePolicy / New-DlpComplianceRule calls it WOULD run, with Mode=TestWithNotifications and OneDriveLocation=All. -Commit: creates the policy in simulation and the rule, then prints the resulting Mode (a Test* value = PASS). Verify with DLPOD-Discovery.ps1. .NOTES Purview — OneDrive for Business DLP. Writes gated behind -Commit; simulation-only (never Enable). No credentials in code. > [CmdletBinding()] param([Parameter(Mandatory)][string]$PolicyName, [string[]]$SensitiveTypes = @('Credit Card Number'), [int]$MinCount = 10,

[ValidateSet('Low','Medium','High')][string]$Confidence = 'High', When set, the rule also requires the content to be shared OUTSIDE the org (the over-share case). [switch]$ExternalShareOnly, Simulation flavour: with or without showing policy tips to users during the test. [ValidateSet('TestWithNotifications','TestWithoutNotifications')][string]$SimulationMode = 'TestWithNotifications', [string]$UserPrincipalName, [switch]$Commit)

DLPOD-Discovery.ps1

Purpose: Builds the OneDrive DLP baseline: every existing DLP compliance policy that TOUCHES the OneDrive location, with its MODE (enforce vs simulation vs disabled), plus a summary of sensitive information types (built-in vs custom) and any EDM schemas available in the tenant. Read-only — makes no changes. Use it to see what already exists before you build simulation policies. HOW TO RUN powershell -ExecutionPolicy Bypass -File .\DLPOD-Discovery.ps1 -CsvPath .\DLPOD-Posture.csv Requires Security & Compliance PowerShell (Connect-IPPSSession via ExchangeOnlineManagement). EXPECTED RESULTS A console table of OneDrive-touching DLP policies (Name, Mode, Locations) and SIT coverage (built-in / custom / EDM counts), plus an optional CSV of the policy inventory. PASS signal: policies you expect to be in simulation report a Test* mode; anything already in Enable that you did not intend is flagged for review. .NOTES Purview — OneDrive for Business DLP. Read-only against Security & Compliance PowerShell. > [CmdletBinding()] param([string]$CsvPath, [string]$UserPrincipalName)

How to run: powershell -ExecutionPolicy Bypass -File .\DLPOD-Discovery.ps1 -CsvPath .\DLPOD-Posture.csv Requires Security & Compliance PowerShell (Connect-IPPSSession via ExchangeOnlineManagement). EXPECTED RESULTS A console table of OneDrive-touching DLP policies (Name, Mode, Locations) and SIT coverage (built-in / custom / EDM counts), plus an optional CSV of the policy inventory. PASS signal: policies you expect to be in simulation report a Test* mode; anything already in Enable that you did not intend is flagged for review. .NOTES Purview — OneDrive for Business DLP. Read-only against Security & Compliance PowerShell. > [CmdletBinding()] param([string]$CsvPath, [string]$UserPrincipalName)

DLPOD-Report.ps1

Purpose: Exports DLP rule matches for OneDrive/SharePoint over a time window so you can classify true-positive vs false-positive and compute the false-positive rate that gates simulation-to-enforcement. Works for policies in simulation AND enforcement — simulation matches are logged the same way. Read-only — queries Search-UnifiedAuditLog only. HOW TO RUN powershell -ExecutionPolicy Bypass -File .\DLPOD-Report.ps1 -Days 14 -CsvPath .\DLPOD-Matches.csv Requires Security & Compliance PowerShell (Connect-IPPSSession) and audit logging enabled. EXPECTED RESULTS A console breakdown of DLP matches by policy, and a per-event CSV (time, user, workload, policy, rule, SIT, action) with a blank 'Disposition' column for you to mark TP/FP. Compute FP rate = FP / (TP + FP). PASS gate: FP rate at/under the agreed threshold with true positives (including external over-shares) still present. .NOTES Purview — OneDrive for Business DLP. Read-only reporting from the unified audit log. No changes made. > [CmdletBinding()] param([int]$Days = 14, [string]$CsvPath, [string]$UserPrincipalName)

How to run: powershell -ExecutionPolicy Bypass -File .\DLPOD-Report.ps1 -Days 14 -CsvPath .\DLPOD-Matches.csv Requires Security & Compliance PowerShell (Connect-IPPSSession) and audit logging enabled. EXPECTED RESULTS A console breakdown of DLP matches by policy, and a per-event CSV (time, user, workload, policy, rule, SIT, action) with a blank 'Disposition' column for you to mark TP/FP. Compute FP rate = FP / (TP + FP). PASS gate: FP rate at/under the agreed threshold with true

positives (including external over-shares) still present. .NOTES Purview — OneDrive for Business DLP. Read-only reporting from the unified audit log. No changes made. > [CmdletBinding()] param([int]$Days = 14, [string]$CsvPath, [string]$UserPrincipalName)

DLPOD-Scope.ps1

Purpose: (1) Reports a OneDrive DLP policy's current location scope and mode, plus its included/excluded OneDrive member-of scope; (2) reports a tenant OneDrive/SharePoint external-SHARING signal from Microsoft Graph as context (read-only, best-effort); and (3) only with -Commit narrows the policy to a PILOT RING by setting OneDriveSharedByMemberOf to a group, so enforcement can be limited to a ring before tenant-wide expansion. Safe by default: -WhatIf reports only; scope writes require -Commit. This helper adjusts SCOPE only — it does NOT flip a policy to enforce (that is a deliberate portal/change-control action) and it does NOT change any tenant sharing setting. HOW TO RUN Report current scope + tenant sharing signal: powershell -File .\DLPOD-Scope.ps1 -PolicyName 'DLP - OneDrive External Share - Simulation' -WhatIf Restrict the policy to a pilot-ring group (still simulation mode): powershell -File .\DLPOD-Scope.ps1 -PolicyName 'DLP - OneDrive External Share - Simulation' ` -PilotRingGroup 'DLPOneDrivePilotRing@contoso.com' -Commit Requires Security & Compliance PowerShell (Connect-IPPSSession); Graph (SharePointTenantSettings.Read.All) is optional for the sharing signal and is skipped gracefully if unavailable. EXPECTED RESULTS -WhatIf: prints the policy's OneDrive scope/mode, the tenant sharing signal (if readable), and the Set-DlpCompliancePolicy call it WOULD run. -Commit: applies OneDriveSharedByMemberOf and re-prints it. PASS: the policy's OneDrive member-of scope now equals the pilot ring and Mode is unchanged (still simulation until you enforce in the portal). .NOTES Purview — OneDrive for Business DLP. Scope changes gated behind -Commit; never changes enforcement mode or tenant sharing. No credentials in code. > [CmdletBinding()] param([Parameter(Mandatory)][string]$PolicyName, [string]$PilotRingGroup, [string]$UserPrincipalName, [switch]$Commit)

How to run: Report current scope + tenant sharing signal: powershell -File .\DLPOD-Scope.ps1 -PolicyName 'DLP - OneDrive External Share - Simulation' -WhatIf Restrict the policy to a pilot-ring group (still simulation mode): powershell -File .\DLPOD-Scope.ps1 -PolicyName 'DLP - OneDrive External Share - Simulation' ` -PilotRingGroup 'DLPOneDrivePilotRing@contoso.com' -Commit Requires Security & Compliance PowerShell (Connect-IPPSSession); Graph (SharePointTenantSettings.Read.All) is optional for the sharing signal and is skipped gracefully if unavailable. EXPECTED RESULTS -WhatIf: prints the policy's OneDrive scope/mode, the tenant sharing signal (if readable), and the Set-DlpCompliancePolicy call it WOULD run. -Commit: applies OneDriveSharedByMemberOf and re-prints it. PASS: the policy's OneDrive member-of scope now equals the pilot ring and Mode is unchanged (still simulation until you enforce in the portal). .NOTES Purview — OneDrive for Business DLP. Scope changes gated behind -Commit; never changes enforcement mode or tenant sharing. No credentials in code. > [CmdletBinding()] param([Parameter(Mandatory)][string]$PolicyName, [string]$PilotRingGroup, [string]$UserPrincipalName, [switch]$Commit)

DLPOD-Validate.ps1

Purpose: Checks the OneDrive DLP policies you built against the solution's validation gates and emits a pass/attention record: (1) each policy actually targets the OneDrive location; (2) its Mode is a recognized value (Test* = simulation / Enable = enforcing / Disable = off) — flagging anything Enabled so an unintended enforcement is caught; (3) the policy's rules carry a ContentContainsSensitiveInformation condition, and (for the external-share policy) an AccessScope of NotInOrganization; and (4) the pilot-ring member-of scope, if set. Read-only — makes no changes; this is the evidence-capture step, not a

remediation. HOW TO RUN Validate the two standard policies: powershell -ExecutionPolicy Bypass -File .\DLPOD-Validate.ps1 -CsvPath .\DLPOD-Validation.csv Validate specific policies by name: powershell -File .\DLPOD-Validate.ps1 -PolicyNames 'DLP - OneDrive Sensitive - Simulation','DLP - OneDrive External Share - Simulation' Requires Security & Compliance PowerShell (Connect-IPPSSession). EXPECTED RESULTS A console table of each policy with OneDriveTargeted / Mode / HasSITCondition / ExternalShareScope / PilotRingScope and a PASS/ATTENTION verdict, plus an optional CSV for the deliverable record. PASS signal: policies target OneDrive, are in the expected mode (simulation during pilot build), and carry the expected conditions. ATTENTION: any policy Enabled unexpectedly or missing a SIT condition is flagged for review. .NOTES Purview — OneDrive for Business DLP. Read-only validation / evidence capture. No changes made. > [CmdletBinding()] param([string[]]$PolicyNames = @('DLP - OneDrive Sensitive - Simulation','DLP - OneDrive External Share - Simulation'), [string]$CsvPath, [string]$UserPrincipalName)

How to run: Validate the two standard policies: powershell -ExecutionPolicy Bypass -File .\DLPOD-Validate.ps1 -CsvPath .\DLPOD-Validation.csv Validate specific policies by name: powershell -File .\DLPOD-Validate.ps1 -PolicyNames 'DLP - OneDrive Sensitive - Simulation','DLP - OneDrive External Share - Simulation' Requires Security & Compliance PowerShell (Connect-IPPSSession). EXPECTED RESULTS A console table of each policy with OneDriveTargeted / Mode / HasSITCondition / ExternalShareScope / PilotRingScope and a PASS/ATTENTION verdict, plus an optional CSV for the deliverable record. PASS signal: policies target OneDrive, are in the expected mode (simulation during pilot build), and carry the expected conditions. ATTENTION: any policy Enabled unexpectedly or missing a SIT condition is flagged for review. .NOTES Purview — OneDrive for Business DLP. Read-only validation / evidence capture. No changes made. > [CmdletBinding()] param([string[]]$PolicyNames = @('DLP - OneDrive Sensitive - Simulation','DLP - OneDrive External Share - Simulation'), [string]$CsvPath, [string]$UserPrincipalName)